VULNERABILITY ASSESSMENT REPORT

Security Assessment of scanme.nmap.org

CONFIDENTIAL

TARGET ASSET	https://scanme.nmap.org
HOSTNAME	scanme.nmap.org
SCAN DATE	Sun, 09 Aug 2026 10:00:48 GMT
SCAN ID	12b2c199-505e-46d7-a40d-6a2407652bd6
OVERALL RISK	F — CRITICAL
TOTAL FINDINGS	22
CLASSIFICATION	Confidential

1. EXECUTIVE SUMMARY

OVERALL THREAT LEVEL

CRITICAL

Risk Score: 90/100 | Health Grade: F

BUSINESS IMPACT STATEMENT

CRITICAL: The assessed system contains severe vulnerabilities that could allow unauthorized remote access, full data compromise, and complete service disruption. Immediate remediation is required.

SEVERITY BREAKDOWN

CRITICAL	1 finding (5%)
HIGH	1 finding (5%)
MEDIUM	4 findings (18%)
LOW	4 findings (18%)
INFO	12 findings (55%)

KEY RECOMMENDATIONS

- Immediately patch 1 critical vulnerability — these represent the highest risk.
- Schedule urgent remediation for 1 high-severity finding within 7 days.
- Plan remediation for 4 medium-severity issues within 30 days.

2. DETAILED FINDINGS

22 vulnerabilities identified, sorted by severity

#1 CRITICAL CVSS: 9.0

[SSLyze] SSL Connection Failed

Affected Asset: https://scanme.nmap.org

Category: ssl

CVE Reference: CWE-319

Description:

Cannot establish TLS to scanme.nmap.org:443: Client network socket disconnected before secure TLS connection was established

Remediation:

Review and fix the SSL/TLS configuration.

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1040 Network Sniffing • T1552 Unsecured Credentials • T1557 Adversary-in-the-Middle • T1078 Valid Accounts

#2 HIGH CVSS: 7.5

HTTPS / TLS Not Available

Affected Asset: scanme.nmap.org:443

Category: ssl

Description:

No TLS/SSL found on port 443 (Client network socket disconnected before secure TLS connection was established). All data transmitted in cleartext. OWASP A02:2021 — Cryptographic Failures.

Remediation:

Enable HTTPS with a valid SSL certificate. Use Let's Encrypt: sudo certbot --nginx -d scanme.nmap.org

MITRE ATT&CK: T1040 — Network Sniffing (Credential Access)

RELATED: T1552 Unsecured Credentials • T1557 Adversary-in-the-Middle

#3 MEDIUM CVSS: 4.3

Missing Security Header: HTTP Strict Transport Security (HSTS)

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: ssl

Description:

HSTS missing — browser connections may be downgraded to HTTP, enabling MITM attacks and session hijacking via T1040 (Network Sniffing). | OWASP: A05:2021 | CWE: CWE-319 | MITRE ATT&CK: T1040 — Network Sniffing

Remediation:

Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

MITRE ATT&CK: T1189 — Drive-by Compromise (Initial Access)

RELATED: T1059.007 JavaScript / JScript • T1539 Steal Web Session Cookie • T1185 Browser Session Hijacking

#4 MEDIUM CVSS: 5.4

Missing Security Header: Content Security Policy (CSP)

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: headers

Description:

CSP missing — attackers can inject and execute arbitrary JavaScript (XSS), enabling credential theft and session hijacking via T1059.007. | OWASP: A05:2021 | CWE: CWE-693 | MITRE ATT&CK: T1059.007 — JavaScript

Remediation:

Add CSP header: Content-Security-Policy: default-src 'self'; script-src 'self' 'nonce-{random}'

MITRE ATT&CK: T1189 — Drive-by Compromise (Initial Access)

RELATED: T1059.007 JavaScript / JScript • T1539 Steal Web Session Cookie • T1185 Browser Session Hijacking

#5 MEDIUM CVSS: 4.3

Missing Security Header: X-Frame-Options (Clickjacking Protection)

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: headers

Description:

X-Frame-Options missing — application can be embedded in iframes on malicious sites for clickjacking attacks. | OWASP: A05:2021 | CWE: CWE-1021 | MITRE ATT&CK: T1185 — Browser Session Hijacking

Remediation:

Add: X-Frame-Options: DENY (or use CSP frame-ancestors directive)

MITRE ATT&CK: T1189 — Drive-by Compromise (Initial Access)

RELATED: T1059.007 JavaScript / JScript • T1539 Steal Web Session Cookie • T1185 Browser Session Hijacking

#6 MEDIUM CVSS: 5.9

HTTP Accessible Without Redirect to HTTPS

Affected Asset: scanme.nmap.org:80 (HTTP Redirect)

Category: misconfig

Description:

HTTP (port 80) serves content without redirecting to HTTPS. Users connecting via HTTP have their traffic transmitted in cleartext, enabling MITM attacks. OWASP A02:2021, MITRE T1040.

Remediation:

Configure 301 redirect: Nginx: return 301 https://$host$request_uri; | Apache: Redirect 301 / https://scanme.nmap.org/

MITRE ATT&CK: T1040 — Network Sniffing (Credential Access)

RELATED: T1552 Unsecured Credentials • T1557 Adversary-in-the-Middle

#7 LOW CVSS: 3.1

Missing Security Header: X-Content-Type-Options

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: headers

Description:

Missing X-Content-Type-Options allows MIME-type sniffing, enabling content injection attacks in older browsers. | OWASP: A05:2021 | CWE: CWE-16 | MITRE ATT&CK: T1190 — Exploit Public-Facing Application

Remediation:

Add: X-Content-Type-Options: nosniff

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1059 Command and Scripting Interpreter • T1068 Exploitation for Privilege Escalation • T1210 Exploitation of Remote Services

#8 LOW CVSS: 2.7

Missing Security Header: Referrer-Policy

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: headers

Description:

Missing Referrer-Policy leaks sensitive URL path information (tokens, session IDs) to third parties via the Referer header. | OWASP: A05:2021 | CWE: CWE-200 | MITRE ATT&CK: T1592 — Gather Victim Host Information

Remediation:

Add: Referrer-Policy: strict-origin-when-cross-origin

MITRE ATT&CK: T1189 — Drive-by Compromise (Initial Access)

RELATED: T1059.007 JavaScript / JScript • T1539 Steal Web Session Cookie • T1185 Browser Session Hijacking

#9 LOW CVSS: 2.0

Missing Security Header: Permissions-Policy (Feature Policy)

Affected Asset: scanme.nmap.org (HTTP Headers)

Category: headers

Description:

Missing Permissions-Policy allows third-party scripts to access sensitive browser APIs (camera, microphone, geolocation). | OWASP: A05:2021 | CWE: CWE-693 | MITRE ATT&CK: T1418 — Software Discovery

Remediation:

Add: Permissions-Policy: camera=(), microphone=(), geolocation=()

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1189 Drive-by Compromise • T1059.007 JavaScript / JScript • T1078 Valid Accounts

#10 LOW CVSS: 3.7

Server Version Disclosed: "Apache/2.4.7 (Ubuntu)"

Affected Asset: scanme.nmap.org (Server Header)

Category: headers

Description:

Server header exposes "Apache/2.4.7 (Ubuntu)" (version 2.4.7 — enables targeted CVE exploitation). Maps to MITRE ATT&CK T1592 (Gather Victim Host Information).

Remediation:

Suppress version: Nginx: server_tokens off; | Apache: ServerTokens Prod; | Express: app.disable("x-powered-by")

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1189 Drive-by Compromise • T1059.007 JavaScript / JScript • T1078 Valid Accounts

#11 INFO CVSS: 0.0

Open Port: 53

Affected Asset: scanme.nmap.org:53

Category: ports

Description:

Port 53 is open on scanme.nmap.org (Node.js fallback — install Docker for full Nmap scan)

Remediation:

Install Docker for real Nmap scanning with service detection, OS fingerprinting, and NSE scripts.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#12 INFO CVSS: 0.0

Open Port: 80

Affected Asset: scanme.nmap.org:80

Category: ports

Description:

Port 80 is open on scanme.nmap.org (Node.js fallback — install Docker for full Nmap scan)

Remediation:

Install Docker for real Nmap scanning with service detection, OS fingerprinting, and NSE scripts.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#13 INFO CVSS: 0.0

[SSLyze] SSL/TLS Grade: F

Affected Asset: scanme.nmap.org:443

Category: ssl

Description:

SSL/TLS analysis complete for scanme.nmap.org:443. Grade: F. Found 2 findings (1 critical, 0 high, 0 medium).

Remediation:

Review findings and fix issues for a better grade.

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1040 Network Sniffing • T1552 Unsecured Credentials • T1557 Adversary-in-the-Middle • T1078 Valid Accounts

#14 INFO CVSS: 0.0

Open Port: 22

Affected Asset: scanme.nmap.org:22

Category: ports

Description:

Port 22 is open on scanme.nmap.org (Node.js fallback — install Docker for full Nmap scan)

Remediation:

Install Docker for real Nmap scanning with service detection, OS fingerprinting, and NSE scripts.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#15 INFO CVSS: 0.0

[ZAP-Fallback] Connection Error

Affected Asset: https://scanme.nmap.org

Category: misconfig

Description:

Could not reach https://scanme.nmap.org: Client network socket disconnected before secure TLS connection was established

Remediation:

Verify target URL.

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1068 Exploitation for Privilege Escalation • T1548 Abuse Elevation Control Mechanism • T1078 Valid Accounts • T1562 Impair Defenses

#16 INFO CVSS: 0.0

[SQLMap-Fallback] Basic Check Done

Affected Asset: https://scanme.nmap.org

Category: injection

Description:

No SQL errors detected. (Docker image not found — run: docker pull parrotsec/sqlmap)

Remediation:

Pull Docker image for real SQLMap.

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1059 Command and Scripting Interpreter • T1068 Exploitation for Privilege Escalation • T1210 Exploitation of Remote Services

#17 INFO CVSS: 0.0

[SSLyze] HTTPS Headers Check Failed

Affected Asset: scanme.nmap.org

Category: ssl

Description:

Could not fetch HTTPS headers: Client network socket disconnected before secure TLS connection was established

Remediation:

Check HTTPS connectivity.

MITRE ATT&CK: T1190 — Exploit Public-Facing Application (Initial Access)

RELATED: T1040 Network Sniffing • T1552 Unsecured Credentials • T1557 Adversary-in-the-Middle • T1078 Valid Accounts

#18 INFO CVSS: 0.0

Open Port: 443

Affected Asset: scanme.nmap.org:443

Category: ports

Description:

Port 443 is open on scanme.nmap.org (Node.js fallback — install Docker for full Nmap scan)

Remediation:

Install Docker for real Nmap scanning with service detection, OS fingerprinting, and NSE scripts.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#19 INFO CVSS: 0.0

DNS A Records: 45.33.32.156

Affected Asset: scanme.nmap.org

Category: dns

Description:

scanme.nmap.org resolves to 1 IP address(es): 45.33.32.156.

Remediation:

Informational — verify IP addresses are expected.

MITRE ATT&CK: T1071 — Application Layer Protocol (Command and Control)

RELATED: T1568 Dynamic Resolution • T1553 Subvert Trust Controls • T1190 Exploit Public-Facing Application

#20 INFO CVSS: 0.0

Port 22 Open: SSH

Affected Asset: scanme.nmap.org:22

Category: ports

Description:

Standard service SSH detected on port 22.

Remediation:

Informational — standard service detected.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#21 INFO CVSS: 0.0

Port 80 Open: HTTP

Affected Asset: scanme.nmap.org:80

Category: ports

Description:

Standard service HTTP detected on port 80.

Remediation:

Informational — standard service detected.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

#22 INFO CVSS: 0.0

Port 443 Open: HTTPS

Affected Asset: scanme.nmap.org:443

Category: ports

Description:

Standard service HTTPS detected on port 443.

Remediation:

Informational — standard service detected.

MITRE ATT&CK: T1046 — Network Service Discovery (Discovery)

RELATED: T1595 Active Scanning • T1135 Network Share Discovery • T1190 Exploit Public-Facing Application • T1210 Exploitation of Remote Services

3. MITRE ATT&CK ATTACK MAP

Tactics and techniques mapped to the MITRE ATT&CK framework (attack.mitre.org)

TECHNIQUE DISTRIBUTION

TECHNIQUE ID	TECHNIQUE	TACTIC	FINDINGS
T1190	Exploit Public-Facing Application	Initial Access	16
T1210	Exploitation of Remote Services	Lateral Movement	9
T1046	Network Service Discovery	Discovery	7
T1595	Active Scanning	Reconnaissance	7
T1135	Network Share Discovery	Discovery	7
T1078	Valid Accounts	Defense Evasion	6
T1189	Drive-by Compromise	Initial Access	6
T1059.007	JavaScript / JScript	Execution	6
T1040	Network Sniffing	Credential Access	5
T1552	Unsecured Credentials	Credential Access	5
T1557	Adversary-in-the-Middle	Credential Access	5
T1539	Steal Web Session Cookie	Credential Access	4
T1185	Browser Session Hijacking	Collection	4
T1068	Exploitation for Privilege Escalation	Privilege Escalation	3
T1059	Command and Scripting Interpreter	Execution	2
T1548	Abuse Elevation Control Mechanism	Privilege Escalation	1
T1562	Impair Defenses	Defense Evasion	1
T1071	Application Layer Protocol	Command and Control	1
T1568	Dynamic Resolution	Command and Control	1
T1553	Subvert Trust Controls	Defense Evasion	1

Mappings are correlational. Technique references: https://attack.mitre.org/techniques/

4. REMEDIATION ROADMAP & COMPLIANCE

Prioritized action plan for security teams

PHASE 1 — IMMEDIATE (0–48 hrs)

- Patch 1 critical vulnerability immediately
- Isolate affected services if exploitation risk is confirmed
- Notify security team and stakeholders

PHASE 2 — SHORT TERM (1–7 days)

- Remediate 1 high-severity finding
- Apply security patches and update dependencies
- Conduct targeted penetration test on affected endpoints

PHASE 3 — SCHEDULED (30 days)

- Address 4 medium-severity issues
- Conduct security awareness training
- Review and update security policies

COMPLIANCE & STANDARDS MAPPING

OWASP Top 10	A01 Broken Access Control, A02 Cryptographic Failures, A03 Injection, A05 Security Misconfiguration
ISO 27001	A.12.6 Technical Vulnerability Management, A.14.2 Security in Development
PCI-DSS	Req 6.3 Identify and protect system components, Req 11.3 Penetration Testing
NIST CSF	ID.RA Risk Assessment, PR.IP Information Protection, DE.CM Continuous Monitoring